

Krishnamargam - API Contract

Version: 1.0

Date: May 2026

Base URL: `https://krishnamargam.babystepsindia.in/api`

Framework: Next.js 14 App Router API Routes

Maintained by: BabyStepsIndia.in

1. Conventions

1.1 Authentication

All authenticated routes require a Supabase session token in the request header:

```
Authorization: Bearer <supabase_access_token>
```

The token is obtained from Supabase Auth after sign in and stored in the client session. Next.js middleware validates the token on every protected route.

1.2 Response Format

All responses follow this envelope:

```
json
{
  "success": true,
  "data": { },
  "error": null
}
```

On error:

```
json
```

```
{
  "success": false,
  "data": null,
  "error": {
    "code": "ENROLLMENT_NOT_FOUND",
    "message": "No active enrollment found for this course."
  }
}
```

1.3 HTTP Status Codes

Code	Meaning
200	Success
201	Created
400	Bad request (validation error)
401	Unauthenticated
403	Forbidden (not admin, or not enrolled)
404	Resource not found
409	Conflict (duplicate)
422	Unprocessable entity
500	Internal server error

1.4 Error Codes

Code	Meaning
AUTH_REQUIRED	No valid session token
ADMIN_REQUIRED	Admin role required
ENROLLMENT_REQUIRED	Must be enrolled to access
ALREADY_ENROLLED	Student already enrolled in course
COURSE_NOT_FOUND	Course slug/id does not exist

Code	Meaning
LESSON_NOT_FOUND	Lesson id does not exist
PAYMENT_FAILED	Razorpay payment not successful
WEBHOOK_INVALID	Razorpay HMAC signature mismatch
OTP_INVALID	WhatsApp OTP incorrect or expired
OTP_MAX_ATTEMPTS	Too many OTP attempts
QUIZ_NOT_FOUND	No quiz configured for this course
VALIDATION_ERROR	Request body failed validation

1.5 Pagination

List endpoints that may return many rows support cursor pagination:

```
GET /api/admin/qa?limit=20&cursor=<last_id>
```

Response includes:

```
json
{
  "data": [ ],
  "pagination": {
    "next_cursor": 142,
    "has_more": true
  }
}
```

2. Public Endpoints (No Auth Required)

2.1 List Published Courses

```
GET /api/courses
```

Query params:

Param	Type	Required	Description
path	string	No	Filter by path slug (e.g. raas)
category	string	No	Filter by category
level	string	No	Beginner / Intermediate / Advanced
sort	string	No	popular / newest / price-asc / price-desc / rating

Response 200:

```
json
```

```
{
  "success": true,
  "data": {
    "courses": [
      {
        "id": 1,
        "slug": "bhagavad-gita-essentials",
        "emoji": "📖",
        "bg_color": "#1a0a00",
        "title_en": "Bhagavad Gita Essentials",
        "title_te": "భగవద్గీత తత్వం",
        "instructor_en": "Pandit Ramakrishna Sharma",
        "instructor_te": "పండిత రామకృష్ణ శర్మ",
        "category": "Bhagavad Gita",
        "level": "Beginner",
        "badge": "Popular",
        "duration": "18h",
        "is_free": false,
        "price": 100,
        "rating": 4.9,
        "review_count": 1240,
        "student_count": 4200,
        "has_quiz": true,
        "path_slug": "raas"
      }
    ],
    "total": 12
  }
}
```

Note: `youtube_video_id` is never returned in any public or student-facing endpoint.

2.2 Get Single Course

```
GET /api/courses/[slug]
```

Response 200:

```
json
```

```

{
  "success": true,
  "data": {
    "course": {
      "id": 1,
      "slug": "bhagavad-gita-essentials",
      "emoji": "📖",
      "bg_color": "#1a0a00",
      "title_en": "Bhagavad Gita Essentials",
      "title_te": "భగవద్గీత తత్వం",
      "description_en": "A comprehensive study...",
      "description_te": "...",
      "instructor_en": "Pandit Ramakrishna Sharma",
      "instructor_te": "పండిత రామకృష్ణ శర్మ",
      "category": "Bhagavad Gita",
      "level": "Beginner",
      "badge": "Popular",
      "duration": "18h",
      "is_free": false,
      "price": 100,
      "rating": 4.9,
      "review_count": 1240,
      "student_count": 4200,
      "has_quiz": true,
      "lessons": [
        {
          "id": 1,
          "section_title": "Introduction",
          "title_en": "Chapter 1-2: Arjuna's Grief",
          "title_te": "...",
          "duration": "42m",
          "order_index": 0,
          "is_preview": true
        }
      ]
    }
  }
}

```

Response 404:

```
json
```

```
{ "success": false, "data": null, "error": { "code": "COURSE_NOT_FOUND", "message":
```

2.3 List Active Learning Paths

```
GET /api/paths
```

Response 200:

```
json
{
  "success": true,
  "data": {
    "paths": [
      {
        "id": 1,
        "slug": "raas",
        "name": "RAAS",
        "emoji": "🕉️",
        "tagline_en": "Vedic & Spiritual Learning",
        "tagline_te": "వేద మరియు ఆధ్యాత్మిక అభ్యాసం",
        "is_active": true,
        "order_index": 1,
        "course_count": 12
      }
    ]
  }
}
```

3. Auth Endpoints

3.1 Send WhatsApp OTP

```
POST /api/auth/otp/send
```

json

```
{
  "mobile": "9876543210",
  "isd_code": "+91"
}
```

Response 200:

json

```
{
  "success": true,
  "data": { "message": "OTP sent via WhatsApp." }
}
```

Response 429:

json

```
{ "success": false, "data": null, "error": { "code": "OTP_MAX_ATTEMPTS", "message":
```



3.2 Verify WhatsApp OTP

POST /api/auth/otp/verify

Request body:

json

```
{
  "mobile": "9876543210",
  "isd_code": "+91",
  "otp": "483920"
}
```

Response 200:

json


```
{
  "success": true,
  "data": { "verified": true }
}
```

Response 400:

json

```
{ "success": false, "data": null, "error": { "code": "OTP_INVALID", "message": "Inco
```

4. Student Endpoints (Auth Required)

4.1 Get My Courses

GET /api/my-courses

Auth: Required

Response 200:

json

```
{
  "success": true,
  "data": {
    "courses": [
      {
        "course_id": 1,
        "slug": "bhagavad-gita-essentials",
        "title_en": "Bhagavad Gita Essentials",
        "title_te": "భగవద్గీత తత్వం",
        "emoji": "📖",
        "bg_color": "#1a0a00",
        "instructor_en": "Pandit Ramakrishna Sharma",
        "duration": "18h",
        "price": 100,
        "intent": "paid",
        "progress_pct": 78,
        "completed_lessons": 4,
        "total_lessons": 6,
        "enrolled_at": "2026-03-10T08:22:00Z",
        "activated_at": "2026-03-10T08:23:00Z"
      }
    ],
    "stats": {
      "total_enrolled": 4,
      "in_progress": 2,
      "completed": 1
    }
  }
}
```

4.2 Submit Enrollment Intent

```
POST /api/enroll/intent
```

Auth: Required

Request body:

```
json
```

```
{
  "course_id": 1,
  "intent": "paid"
}
```

`intent` must be one of: `paid` | `cannot_pay` | `not_willing_to_pay`

Response 201 (for `cannot_pay` or `not_willing_to_pay`):

json

```
{
  "success": true,
  "data": {
    "enrolled": true,
    "is_active": true,
    "intent": "cannot_pay",
    "message": "Enrollment activated. Start learning now!"
  }
}
```

Response 201 (for `paid` — triggers payment flow):

json

```
{
  "success": true,
  "data": {
    "enrolled": false,
    "is_active": false,
    "intent": "paid",
    "next_step": "payment",
    "course_id": 1
  }
}
```

Response 409:

json

```
{ "success": false, "data": null, "error": { "code": "ALREADY_ENROLLED", "message":
```



4.3 Poll Enrollment Status

```
GET /api/enrollment/status/[courseId]
```

Auth: Required

Used by client to poll after Razorpay payment until `is_active = true`.

Response 200:

```
json
{
  "success": true,
  "data": {
    "is_active": true,
    "activated_at": "2026-03-10T08:23:15Z",
    "course_slug": "bhagavad-gita-essentials"
  }
}
```

4.4 Get Signed Watch Token

```
GET /api/watch/token?lesson_id=5
```

Auth: Required + enrolled

This is the URL masking endpoint. Returns a short-lived signed token that resolves to the YouTube embed URL on the server. The YouTube video ID is never sent to the client.

Response 200:

```
json
```

```
{
  "success": true,
  "data": {
    "embed_url": "https://www.youtube.com/embed/[VIDEO_ID]?enablejsapi=1&origin=http",
    "token_expires_at": "2026-03-10T09:23:15Z",
    "lesson_id": 5,
    "lesson_title_en": "Chapter 3-4: Karma Yoga",
    "lesson_title_te": "...",
    "duration": "38m"
  }
}
```

The embed_url contains the YouTube video ID but is served only via HTTPS to authenticated enrolled users. The token expires in 1 hour.

Response 403:

```
json
{ "success": false, "data": null, "error": { "code": "ENROLLMENT_REQUIRED", "message": "Enrollment required" } }
```

4.5 Save Watch Session

POST /api/watch/session

Auth: Required

Called every 10 seconds by the YouTube iFrame API polling interval.

Request body:

```
json
```

```
{
  "lesson_id": 5,
  "course_id": 1,
  "max_watch_pct": 65,
  "total_watch_seconds": 1420,
  "completed": false
}
```

If `completed: true` or `max_watch_pct >= 90`, server marks lesson as complete in `user_progress`.

Response 200:

```
json
{
  "success": true,
  "data": {
    "lesson_completed": true,
    "course_progress_pct": 83
  }
}
```

4.6 Get Course Progress

```
GET /api/progress/[courseId]
```

Auth: Required

Response 200:

```
json
```

```
{
  "success": true,
  "data": {
    "course_id": 1,
    "progress_pct": 78,
    "completed_lessons": [1, 2, 3, 4],
    "total_lessons": 6,
    "completed_at": null
  }
}
```

4.7 Get Notes

```
GET /api/notes/[courseId]
```

Auth: Required

Response 200:

```
json
{
  "success": true,
  "data": {
    "course_id": 1,
    "content": "Lesson 2 notes: The Gayatri Mantra has 24 syllables...",
    "updated_at": "2026-03-10T10:15:00Z"
  }
}
```

4.8 Save Notes

```
POST /api/notes/[courseId]
```

Auth: Required

Request body:

Response 200:

json

```
{  
  "success": true,  
  "data": { "saved": true, "updated_at": "2026-03-10T10:15:00Z" }  
}
```

4.9 Get Q&A for Lesson

```
GET /api/qa/[lessonId]?limit=20&cursor=<last_id>
```

Auth: Required (any logged-in user)

Response 200:

json


```
{
  "success": true,
  "data": {
    "questions": [
      {
        "id": 12,
        "question_text": "What is the significance of the chariot in Chapter 1?",
        "student_name": "Suresh Reddy",
        "avatar_initials": "SR",
        "asked_at": "2026-03-10T09:00:00Z",
        "is_answered": true,
        "reply": {
          "reply_text": "The chariot represents the human body. The horses are the s",
          "replied_at": "2026-03-10T11:00:00Z"
        }
      }
    ],
    "pagination": {
      "next_cursor": 10,
      "has_more": false
    }
  }
}
```

4.10 Post Q&A Question

```
POST /api/qa/[lessonId]
```

Auth: Required (any logged-in user)

Request body:

```
json
{
  "course_id": 1,
  "question_text": "What is the significance of the chariot in Chapter 1?"
}
```

Response 201:

json

```
{
  "success": true,
  "data": {
    "question_id": 12,
    "message": "Question submitted. You'll be notified when answered."
  }
}
```

4.11 Get Quiz Questions

GET /api/quiz/[courseId]

Auth: Required + enrolled

Returns questions without revealing the correct answer.

Response 200:

json

```
{
  "success": true,
  "data": {
    "course_id": 1,
    "pass_pct": 80,
    "questions": [
      {
        "id": 1,
        "question_text": "What does the chariot represent in the Bhagavad Gita?",
        "option_a": "The battlefield",
        "option_b": "The human body",
        "option_c": "Lord Krishna's vehicle",
        "option_d": "The mind",
        "order_index": 0
      }
    ],
    "total_questions": 5
  }
}
```

Response 404:

json

```
{ "success": false, "data": null, "error": { "code": "QUIZ_NOT_FOUND", "message": "N
```

4.12 Submit Quiz Attempt

POST /api/quiz/[courseId]/attempt

Auth: Required + enrolled

Request body:

json

```
{  
  "answers": {  
    "1": "b",  
    "2": "a",  
    "3": "c",  
    "4": "d",  
    "5": "b"  
  }  
}
```

Response 200:

json

```
{
  "success": true,
  "data": {
    "total_questions": 5,
    "correct_answers": 4,
    "score_pct": 80,
    "passed": true,
    "pass_pct": 80,
    "course_completed": true,
    "results": [
      { "question_id": 1, "your_answer": "b", "correct_answer": "b", "correct": true },
      { "question_id": 2, "your_answer": "a", "correct_answer": "a", "correct": true },
      { "question_id": 3, "your_answer": "c", "correct_answer": "d", "correct": false },
      { "question_id": 4, "your_answer": "d", "correct_answer": "d", "correct": true },
      { "question_id": 5, "your_answer": "b", "correct_answer": "b", "correct": true }
    ]
  }
}
```

5. Payment Endpoints

5.1 Create Razorpay Order

POST /api/payment/create-order

Auth: Required

Request body:

```
json
{
  "course_id": 1
}
```

Response 201:

```
json
```

```
{
  "success": true,
  "data": {
    "order_id": "order_PQRxyz123",
    "amount": 10000,
    "currency": "INR",
    "razorpay_key_id": "rzp_live_xxxxxxxxx"
  }
}
```

Amount is in paise (100 INR = 10000 paise).

Response 409:

json

```
{ "success": false, "data": null, "error": { "code": "ALREADY_ENROLLED", "message":
```

5.2 Razorpay Webhook

POST /api/payment/webhook

Auth: None (validated via Razorpay HMAC signature)

Headers:

x-razorpay-signature: <hmac_sha256_signature>

Request body (from Razorpay):

json

```
{
  "event": "payment.captured",
  "payload": {
    "payment": {
      "entity": {
        "id": "pay_ABC123",
        "order_id": "order_PQRxyz123",
        "amount": 10000,
        "currency": "INR",
        "status": "captured"
      }
    }
  }
}
```

Server processing:

1. Verify HMAC signature using `RAZORPAY_WEBHOOK_SECRET`
2. Lookup `payment_logs` by `razorpay_order_id`
3. Update `payment_logs.status = 'paid'`, set `razorpay_payment_id`,
`webhook_received_at`
4. Database trigger auto-activates `enrollments.is_active = TRUE`
5. Send confirmation email via Resend
6. Return 200

Response 200:

```
json
{ "success": true, "data": { "received": true } }
```

Response 400:

```
json
{ "success": false, "data": null, "error": { "code": "WEBHOOK_INVALID", "message": "Invalid webhook signature" } }
```

6. Admin Endpoints (Admin Auth Required)

All admin endpoints require `is_admin = TRUE` on the authenticated user's profile. Return 403 otherwise.

6.1 Learning Paths

List All Paths

```
GET /api/admin/paths
```

Response 200:

```
json
{
  "success": true,
  "data": {
    "paths": [
      {
        "id": 1,
        "slug": "raas",
        "name": "RAAS",
        "emoji": "🕉️",
        "tagline_en": "Vedic & Spiritual Learning",
        "tagline_te": "...",
        "description_en": "...",
        "description_te": "...",
        "is_active": true,
        "order_index": 1,
        "course_count": 12
      }
    ]
  }
}
```

Create Path

```
POST /api/admin/paths
```

Request body:

```
json
{
  "slug": "daas",
  "name": "DAAS",
  "emoji": "👤",
  "tagline_en": "Coming Soon",
  "tagline_te": "త్వరలో వస్తోంది",
  "description_en": "A new spiritual path.",
  "description_te": "...",
  "is_active": false,
  "order_index": 2
}
```

Response 201:

```
json
{ "success": true, "data": { "id": 2, "slug": "daas" } }
```

Update Path

```
PUT /api/admin/paths/[id]
```

Request body: Any subset of path fields.

Response 200:

```
json
{ "success": true, "data": { "updated": true } }
```

Delete Path

```
DELETE /api/admin/paths/[id]
```

Response 200:

```
json
{ "success": true, "data": { "deleted": true } }
```


json

```
{ "success": false, "data": null, "error": { "code": "VALIDATION_ERROR", "message":
```

Reorder Paths

```
PUT /api/admin/paths/reorder
```

Request body:

json

```
{  
  "order": [  
    { "id": 1, "order_index": 0 },  
    { "id": 2, "order_index": 1 }  
  ]  
}
```

Response 200:

json

```
{ "success": true, "data": { "updated": true } }
```

6.2 Courses

List All Courses

```
GET /api/admin/courses?path=raas&level=Beginner&status=published
```

Response 200:

json

```
{
  "success": true,
  "data": {
    "courses": [
      {
        "id": 1,
        "slug": "bhagavad-gita-essentials",
        "emoji": "📖",
        "title_en": "Bhagavad Gita Essentials",
        "title_te": "భగవద్గీత తత్వం",
        "path_name": "RAAS",
        "category": "Bhagavad Gita",
        "level": "Beginner",
        "price": 100,
        "is_published": true,
        "has_quiz": true,
        "order_index": 0,
        "student_count": 4200
      }
    ],
    "total": 12
  }
}
```

Create Course

POST /api/admin/courses

Request body:

json

```
{
  "path_id": 1,
  "slug": "bhagavad-gita-essentials",
  "emoji": "📖",
  "bg_color": "#1a0a00",
  "title_en": "Bhagavad Gita Essentials",
  "title_te": "భగవద్గీత తత్వం",
  "description_en": "A comprehensive study...",
  "description_te": "...",
  "instructor_en": "Pandit Ramakrishna Sharma",
  "instructor_te": "పండిత రామకృష్ణ శర్మ",
  "category": "Bhagavad Gita",
  "level": "Beginner",
  "badge": "Popular",
  "duration": "18h",
  "is_free": false,
  "price": 100,
  "has_quiz": true,
  "quiz_pass_pct": 80,
  "is_published": false,
  "order_index": 0
}
```

Response 201:

json

```
{ "success": true, "data": { "id": 1, "slug": "bhagavad-gita-essentials" } }
```

Update Course

PUT /api/admin/courses/[id]

Request body: Any subset of course fields.

Response 200:

json

```
{ "success": true, "data": { "updated": true } }
```

Soft Delete Course

```
DELETE /api/admin/courses/[id]
```

Sets `is_deleted = TRUE`. Data preserved for enrolled students.

Response 200:

json

```
{ "success": true, "data": { "deleted": true } }
```

Reorder Courses

```
PUT /api/admin/courses/reorder
```

Request body:

json

```
{
  "order": [
    { "id": 1, "order_index": 0 },
    { "id": 5, "order_index": 1 },
    { "id": 3, "order_index": 2 }
  ]
}
```

Response 200:

json

```
{ "success": true, "data": { "updated": true } }
```

6.3 Lessons

Create Lesson

```
POST /api/admin/courses/[courseId]/lessons
```

json

```
{
  "section_title": "Introduction",
  "title_en": "Chapter 1-2: Arjuna's Grief",
  "title_te": "...",
  "youtube_video_id": "dQw4w9WgXcQ",
  "duration": "42m",
  "order_index": 0,
  "is_preview": false
}
```

Response 201:

json

```
{ "success": true, "data": { "id": 1 } }
```

Update Lesson

```
PUT /api/admin/lessons/[id]
```

Request body: Any subset of lesson fields.

Response 200:

json

```
{ "success": true, "data": { "updated": true } }
```

Delete Lesson

```
DELETE /api/admin/lessons/[id]
```

Response 200:

json

```
{ "success": true, "data": { "deleted": true } }
```

Reorder Lessons

```
PUT /api/admin/courses/[courseId]/lessons/reorder
```

Request body:

```
json
{
  "order": [
    { "id": 1, "order_index": 0 },
    { "id": 2, "order_index": 1 }
  ]
}
```

Response 200:

```
json
{ "success": true, "data": { "updated": true } }
```

6.4 Quiz Questions

List Quiz Questions

```
GET /api/admin/courses/[courseId]/quiz
```

Response 200:

```
json
```

```
{
  "success": true,
  "data": {
    "course_id": 1,
    "has_quiz": true,
    "quiz_pass_pct": 80,
    "questions": [
      {
        "id": 1,
        "question_text": "What does the chariot represent?",
        "option_a": "The battlefield",
        "option_b": "The human body",
        "option_c": "Lord Krishna's vehicle",
        "option_d": "The mind",
        "correct_option": "b",
        "order_index": 0
      }
    ]
  }
}
```

Add Quiz Question

```
POST /api/admin/courses/[courseId]/quiz
```

Request body:

```
json

{
  "question_text": "What does the chariot represent?",
  "option_a": "The battlefield",
  "option_b": "The human body",
  "option_c": "Lord Krishna's vehicle",
  "option_d": "The mind",
  "correct_option": "b",
  "order_index": 0
}
```

Response 201:

```
json
```

```
{ "success": true, "data": { "id": 1 } }
```

Update Quiz Question

```
PUT /api/admin/quiz/[questionId]
```

Response 200:

json

```
{ "success": true, "data": { "updated": true } }
```

Delete Quiz Question

```
DELETE /api/admin/quiz/[questionId]
```

Response 200:

json

```
{ "success": true, "data": { "deleted": true } }
```

6.5 Enrollments

List All Enrollments

```
GET /api/admin/enrollments?intent=paid&status=active&limit=20&cursor=<id>
```

Query params:

Param	Values
intent	paid / cannot_pay / not_willing_to_pay / all
status	active / inactive / all
course_id	integer

Response 200:

json

```
{
  "success": true,
  "data": {
    "enrollments": [
      {
        "id": 1,
        "student_name": "Suresh Reddy",
        "student_email": "suresh@example.com",
        "student_mobile": "+91 98765 43210",
        "course_title": "Bhagavad Gita Essentials",
        "intent": "paid",
        "amount_paid": 100,
        "is_active": true,
        "enrolled_at": "2026-03-10T08:22:00Z",
        "activated_at": "2026-03-10T08:23:00Z"
      }
    ],
    "summary": {
      "total": 120,
      "paid": 45,
      "cannot_pay": 60,
      "not_willing_to_pay": 15
    },
    "pagination": { "next_cursor": 100, "has_more": true }
  }
}
```

6.6 Q&A Hub

List All Questions

```
GET /api/admin/qa?course_id=1&lesson_id=5&answered=false&limit=20&cursor=<id>
```

Response 200:

json

```
{
  "success": true,
  "data": {
    "questions": [
      {
        "question_id": 12,
        "question_text": "What is the significance of the chariot?",
        "student_name": "Suresh Reddy",
        "avatar_initials": "SR",
        "course_title": "Bhagavad Gita Essentials",
        "lesson_title": "Chapter 1-2: Arjuna's Grief",
        "asked_at": "2026-03-10T09:00:00Z",
        "is_answered": false,
        "reply": null
      }
    ],
    "unanswered_count": 7,
    "pagination": { "next_cursor": 10, "has_more": false }
  }
}
```

Submit Reply

```
POST /api/admin/qa/[questionId]/reply
```

Request body:

json

```
{
  "reply_text": "The chariot represents the human body. The horses are the senses..."
}
```

Response 201:

json

```
{ "success": true, "data": { "reply_id": 5, "student_notified": true } }
```

Edit Reply

```
PUT /api/admin/qa/[questionId]/reply
```

Request body:

```
json
{
  "reply_text": "Updated reply text..."
}
```

Response 200:

```
json
{ "success": true, "data": { "updated": true } }
```

Delete Question

```
DELETE /api/admin/qa/[questionId]
```

Sets `is_deleted = TRUE`.

Response 200:

```
json
{ "success": true, "data": { "deleted": true } }
```

6.7 Analytics

Intent Analytics

```
GET /api/admin/analytics/intents?granularity=day&from=2026-01-01&to=2026-03-31
```

Query params:

Param	Values	Default
granularity	day / week / month	day
from	ISO date	30 days ago
to	ISO date	today
course_id	integer	all courses

Response 200:

```
json
{
  "success": true,
  "data": {
    "granularity": "day",
    "series": [
      {
        "date": "2026-03-10",
        "paid_count": 5,
        "cannot_pay_count": 12,
        "not_willing_count": 3,
        "total_revenue": 500
      }
    ],
    "totals": {
      "paid": 45,
      "cannot_pay": 60,
      "not_willing": 15,
      "total_revenue": 4500
    }
  }
}
```

Watch Analytics

```
GET /api/admin/analytics/watch?course_id=1
```

Response 200:

json

```
{
  "success": true,
  "data": {
    "lessons": [
      {
        "lesson_id": 1,
        "lesson_title": "Chapter 1-2: Arjuna's Grief",
        "unique_viewers": 120,
        "avg_watch_pct": 82,
        "avg_watch_minutes": 34.5
      }
    ]
  }
}
```

Course Analytics

GET /api/admin/analytics/courses

Response 200:

json

```
{
  "success": true,
  "data": {
    "courses": [
      {
        "course_id": 1,
        "title_en": "Bhagavad Gita Essentials",
        "enrolled_count": 120,
        "completion_rate_pct": 34,
        "avg_progress_pct": 58,
        "quiz_pass_rate_pct": 72
      }
    ]
  }
}
```

6.8 Exports

Export Students (CSV)

```
GET /api/admin/exports/students?from=2026-01-01&to=2026-03-31
```

Response: Content-Type: text/csv

```
full_name,email,isd_code,mobile,mobile_verified,registered_at  
Suresh Reddy,suresh@example.com,+91,9876543210,true,2026-03-10T08:00:00Z
```

Export Enrollments (CSV)

```
GET /api/admin/exports/enrollments?from=2026-01-01&to=2026-03-31
```

Response: Content-Type: text/csv

```
student_name,email,course_title,intent,amount_paid,enrolled_at,activated_at  
Suresh Reddy,suresh@example.com,Bhagavad Gita Essentials,paid,100,2026-03-10T08:22:00Z,2026-03-10T08:23:00Z
```

Export Q&A (CSV)

```
GET /api/admin/exports/qa?from=2026-01-01&to=2026-03-31
```

Response: Content-Type: text/csv

```
course_title,lesson_title,student_name,question,admin_reply,asked_at,replied_at  
Bhagavad Gita Essentials,Chapter 1-2,Suresh Reddy,What is the chariot?,The chariot represents...,2026-03-10T09:00:00Z,2026-03-10T11:00:00Z
```

Export Analytics (CSV)

```
GET /api/admin/exports/analytics?granularity=day&from=2026-01-01&to=2026-03-31
```

Response: Content-Type: text/csv

```
date,paid_count,cannot_pay_count,not_willing_count,total_revenue
2026-03-10,5,12,3,500
2026-03-11,3,8,2,300
```

7. Middleware

7.1 Student Auth Middleware

Applied to all `/api/my-courses`, `/api/enroll/*`, `/api/watch/*`, `/api/notes/*`, `/api/qa/*`, `/api/quiz/*`, `/api/progress/*`:

typescript

```
// middleware.ts
const session = await supabase.auth.getSession();
if (!session.data.session) {
  return NextResponse.json({ success: false, error: { code: 'AUTH_REQUIRED' } }, { s
}
```

7.2 Admin Auth Middleware

Applied to all `/api/admin/*`:

typescript

```
const { data: profile } = await supabase
  .from('profiles')
  .select('is_admin')
  .eq('id', session.data.session.user.id)
  .single();

if (!profile?.is_admin) {
  return NextResponse.json({ success: false, error: { code: 'ADMIN_REQUIRED' } }, {
}
```

7.3 Enrollment Check Middleware

Applied to `/api/watch/token`, `/api/quiz/*`:

typescript

```

const { data: enrollment } = await supabase
  .from('enrollments')
  .select('is_active')
  .eq('user_id', userId)
  .eq('course_id', courseId)
  .single();

if (!enrollment?.is_active) {
  return NextResponse.json({ success: false, error: { code: 'ENROLLMENT_REQUIRED' } })
}

```

8. Rate Limits

Endpoint	Limit
POST /api/auth/otp/send	3 requests per mobile per 10 minutes
POST /api/auth/otp/verify	5 attempts per mobile per 10 minutes
POST /api/watch/session	10 requests per minute per user
POST /api/qa/[lessonId]	5 questions per lesson per user per day
POST /api/quiz/[courseId]/attempt	Unlimited (no rate limit on quiz retakes)
GET /api/admin/exports/*	10 requests per hour per admin

9. Security Notes

Concern	Mitigation
YouTube video ID exposure	Never returned in any API response. Served only via signed embed URL to authenticated enrolled users
Razorpay webhook spoofing	HMAC-SHA256 signature verified using <code>RAZORPAY_WEBHOOK_SECRET</code> before any processing

Concern	Mitigation
Admin route access	<code>is_admin</code> flag checked server-side on every admin API call, not just middleware
OTP brute force	Max 3 sends per number per 10 min, max 5 verification attempts before logout
SQL injection	All queries via Supabase client with parameterised queries — no raw SQL in API layer
CSRF	Next.js App Router API routes are not vulnerable to CSRF; Supabase tokens are Bearer tokens

API Contract maintained by BabyStepsIndia.in · © 2026 Krishnamargam